

Risk Assessment Methodology

Document Control

Document ID: ISMS-RAM-001 | Version 1.0 | Owner: ISMS Manager | Status: Draft for Portfolio Simulation | 14 August 2026

Purpose

Define a repeatable, consistent and risk-based method for identifying, analyzing and evaluating information-security risks within the ISMS.

Risk Model

Risk = Likelihood × Impact. Likelihood considers probability of an adverse event; impact considers consequences to confidentiality, integrity, availability, legal/compliance obligations, finance, customers, operations and reputation.

Assessment Process

Identify asset/process and information; identify threat/event and vulnerability; identify existing controls; assess likelihood and impact; calculate inherent risk; evaluate against acceptance criteria; determine treatment; estimate residual risk; assign ownership and approval.

Likelihood Scale

Score	Definition
1 — Rare	Highly unlikely; strong controls and limited exposure.
2 — Unlikely	Could occur but is not expected under normal conditions.
3 — Possible	Could occur periodically or under plausible conditions.
4 — Likely	Expected to occur or has credible recurring exposure.
5 — Almost Certain	Very likely or frequent without effective additional treatment.

Impact Scale

Score	Definition
1 — Insignificant	Minimal operational, financial, legal, customer or reputational effect.
2 — Minor	Limited disruption or localized impact.
3 — Moderate	Material business or customer impact requiring management attention.
4 — Major	Significant disruption, financial/legal/customer impact or loss of critical information.
5 — Severe	Critical disruption, major breach, serious legal/regulatory impact or severe loss of trust.

Risk Rating

1–4 Low; 5–9 Moderate; 10–16 High; 17–25 Critical.

Review

Review risks at planned intervals and after significant changes, incidents, new technologies, suppliers, legal requirements or business conditions.